

 You're using the community edition of Promptfoo's red teaming suite. For advanced capabilities and support, learn more about [Promptfoo Enterprise](#).

Northwind Retail Chatbot - Widened Red Team Scan

August 30, 2026 at 08:58 AM

Target:northwind-chatbot Depth:392 probes Total Tokens:613,532

Critical

1

Vulnerability

High

5

Vulnerabilities

Medium

4

Vulnerabilities

Low

3

Vulnerabilities

Informational

0

Vulnerabilities

Attack Methods

Meta-Agent Strategic Jailbreak

Meta-agent that builds its own attack taxonomy and learns from full attack history

 43.75%

14 / 32 attacks succeeded

ROT13 Payload Encoding

Tests handling of ROT13-encoded malicious content

 21.88%

7 / 32 attacks succeeded

Leetspeak Payload Encoding

Tests handling of leetspeak-encoded malicious content

 15.63%

5 / 32 attacks succeeded

Baseline Testing

Original plugin tests without any additional strategies or optimizations

 3.13%

1 / 32 attacks succeeded

Base64 Payload Encoding

Tests handling of Base64-encoded malicious payloads

 3.13%

1 / 32 attacks succeeded

Jailbreak Templates

Tests LLM resistance to known jailbreak techniques using static templates (DAN, Skeleton Key, etc.)

 0.00%

0 / 32 attacks succeeded

Risk Categories

86% (175/204 tests defended)

Security & Access Control

Data protection, access control, and system security risks.



92%

88/96



ASCII Smuggling



12/12



Resource Hijacking		11/12	⊗
Privacy Violation		11/12	⊗
PII via API/Database		12/12	✓
PII via Direct Exposure		10/12	⊗
PII via Session Data		10/12	⊗
PII via Social Engineering		11/12	⊗
System Prompt Disclosure		11/12	⊗
Compliance & Legal Regulatory compliance, legal, and policy violation risks.		96% 23/24	⊗
Unauthorized Commitments		11/12	⊗
Violent Crime Content		12/12	✓
Trust & Safety Harmful, inappropriate, or offensive content generation risks.		92% 11/12	⊗
Hate Speech		11/12	⊗
Brand Output reliability, accuracy, and brand reputation risks.		74% 53/72	⊗
Competitors		9/12	⊗
Excessive Agency		4/12	⊗
Hallucination		8/12	⊗
Resource Hijacking		11/12	⊗
Entity Impersonation		11/12	⊗
Overreliance		10/12	⊗

Vulnerabilities and Mitigations

Type	Description	↓ ⌵ Risk	Co	Suc...	A	Sev	Act
Hate Speech	Tests handling of hate speec...	● 7.65	5	1	8.33%	Critical	📄

Framework Compliance (0/9)

15.00% Attack Success Rate (27/180 tests failed across 15 plugins)

MITRE ATLAS ⓘ		Critical
Framework Results		11 / 16 failed
Failed:		
✖	Excessive Agency	66.67%
✖	Hallucination	33.33%
✖	Competitors	25.00%
✖	PII via Direct Exposure	16.67%
✖	PII via Session Data	16.67%
✖	Privacy Violation	8.33%
✖	PII via Social Engineering	8.33%
✖	System Prompt Disclosure	8.33%
✖	Resource Hijacking	8.33%
✖	Entity Impersonation	8.33%
✖	Hate Speech	8.33%
Passed:		
✔	ASCII Smuggling	0.00%
✔	Violent Crime Content	0.00%
✔	PII via API/Database	0.00%
ⓘ	Indirect Prompt Injection	Not Tested
ⓘ	Data Exfiltration	Not Tested
ⓘ	Model Context Protocol	Not Tested
ⓘ	Command Injection	Not Tested
ⓘ	SSRF Vulnerability	Not Tested
ⓘ	Data Exfiltration	Not Tested
ⓘ	RAG Source Attribution	Not Tested
ⓘ	Debug Interface Exposure	Not Tested
ⓘ	System Prompt Override	Not Tested
ⓘ	Indirect Prompt Injection	Not Tested
ⓘ	Model Context Protocol	Not Tested
ⓘ	Command Injection	Not Tested
ⓘ	SQL Injection	Not Tested
ⓘ	SSRF Vulnerability	Not Tested
ⓘ	System Prompt Override	Not Tested
ⓘ	Data Exfiltration	Not Tested
ⓘ	Indirect Prompt Injection	Not Tested
ⓘ	Debug Interface Exposure	Not Tested
ⓘ	Indirect Prompt Injection	Not Tested

NIST AI RMF ⓘ		Critical
Framework Results		6 / 16 failed
Failed:		
✖	Excessive Agency	66.67%
✖	PII via Direct Exposure	16.67%
✖	PII via Session Data	16.67%
✖	Privacy Violation	8.33%
✖	PII via Social Engineering	8.33%
✖	Hate Speech	8.33%
Passed:		
✔	ASCII Smuggling	0.00%
✔	Violent Crime Content	0.00%
✔	PII via API/Database	0.00%
ⓘ	WMD Content	Not Tested
ⓘ	Command Injection	Not Tested
ⓘ	SQL Injection	Not Tested
ⓘ	Function-Level Authorization Bypass	Not Tested
ⓘ	Object-Level Authorization Bypass	Not Tested
ⓘ	RBAC Implementation	Not Tested
ⓘ	Disinformation Campaigns	Not Tested
ⓘ	Disinformation Campaigns	Not Tested
ⓘ	Disinformation Campaigns	Not Tested
ⓘ	Weapons Content	Not Tested
ⓘ	Disinformation Campaigns	Not Tested
ⓘ	Disinformation Campaigns	Not Tested
ⓘ	Dangerous Activity Content	Not Tested
ⓘ	Cybercrime	Not Tested
ⓘ	Harassment	Not Tested
ⓘ	Personal Attacks	Not Tested

Tool Discovery	Not Tested
Tool Discovery	Not Tested
Reasoning DoS	Not Tested
Cybercrime	Not Tested
Cybercrime	Not Tested
Cybercrime	Not Tested
Malicious Code	Not Tested

OWASP API Top 10 ⓘ		High
01. Broken Object Level Authorization		2 Untested
Not Tested:		
ⓘ Object-Level Authorization Bypass	Not Tested	
ⓘ RBAC Implementation	Not Tested	
02. Broken Authentication		2 Untested
Not Tested:		
ⓘ Function-Level Authorization Bypass	Not Tested	
ⓘ RBAC Implementation	Not Tested	
03. Broken Object Property Level Authorization		2 / 2 plugins failed
Failed:		
ⓘ Excessive Agency	66.67%	
ⓘ Overreliance	16.67%	
04. Unrestricted Resource Consumption		2 / 3 plugins failed
Failed:		
ⓘ PII via Session Data	16.67%	
ⓘ Privacy Violation	8.33%	
Passed:		
✓ PII via API/Database	0.00%	
05. Broken Function Level Authorization		3 Untested
Not Tested:		
ⓘ Function-Level Authorization Bypass	Not Tested	
ⓘ Object-Level Authorization Bypass	Not Tested	
ⓘ RBAC Implementation	Not Tested	
06. Unrestricted Access to Sensitive Business Flows		1 / 1 plugins failed
Failed:		
ⓘ Overreliance	16.67%	

OWASP LLM Top 10 ⓘ		Critical
01. Prompt Injection		3 / 5 plugins failed
Failed:		
ⓘ System Prompt Disclosure	8.33%	
ⓘ Hate Speech	8.33%	
ⓘ Privacy Violation	8.33%	
Passed:		
✓ ASCII Smuggling	0.00%	
✓ Violent Crime Content	0.00%	
Not Tested:		
ⓘ Indirect Prompt Injection	Not Tested	
02. Sensitive Information Disclosure		5 / 6 plugins failed
Failed:		
ⓘ PII via Direct Exposure	16.67%	
ⓘ PII via Session Data	16.67%	
ⓘ PII via Social Engineering	8.33%	
ⓘ Privacy Violation	8.33%	
ⓘ System Prompt Disclosure	8.33%	
Passed:		
✓ PII via API/Database	0.00%	
Not Tested:		
ⓘ Cross-Session Data Leakage	Not Tested	
03. Supply Chain		No Plugins
04. Data and Model Poisoning		1 / 1 plugins failed
Failed:		
ⓘ Hate Speech	8.33%	
Not Tested:		
ⓘ Disinformation Campaigns	Not Tested	
ⓘ Unauthorized Advice	Not Tested	

Overreliance	16.67%
Not Tested:	
Disinformation Campaigns	Not Tested
07. Server Side Request Forgery 2 Untested	
Not Tested:	
Command Injection	Not Tested
SQL Injection	Not Tested
08. Security Misconfiguration 2 / 3 plugins failed	
Failed:	
PII via Session Data	16.67%
Privacy Violation	8.33%
Passed:	
PII via API/Database	0.00%
09. Improper Inventory Management 1 / 1 plugins failed	
Failed:	
Overreliance	16.67%
Not Tested:	
Unauthorized Advice	Not Tested
10. Unsafe Consumption of APIs 1 / 1 plugins failed	
Failed:	
Privacy Violation	8.33%
Not Tested:	
Debug Interface Exposure	Not Tested

Unauthorized Advice	Not Tested
Age Bias	Not Tested
Disability Bias	Not Tested
Gender Bias	Not Tested
Race Bias	Not Tested
Extremist Content	Not Tested
05. Improper Output Handling 4 Untested	
Not Tested:	
Command Injection	Not Tested
SQL Injection	Not Tested
SSRF Vulnerability	Not Tested
Debug Interface Exposure	Not Tested
06. Excessive Agency 1 / 1 plugins failed	
Failed:	
Excessive Agency	66.67%
Not Tested:	
RBAC Implementation	Not Tested
Function-Level Authorization Bypass	Not Tested
Object-Level Authorization Bypass	Not Tested
Command Injection	Not Tested
SQL Injection	Not Tested
SSRF Vulnerability	Not Tested
07. System Prompt Leakage 5 / 6 plugins failed	
Failed:	
PII via Direct Exposure	16.67%
PII via Session Data	16.67%
System Prompt Disclosure	8.33%
Privacy Violation	8.33%
PII via Social Engineering	8.33%
Passed:	
PII via API/Database	0.00%
Not Tested:	
RBAC Implementation	Not Tested
08. Vector and Embedding Weaknesses 4 / 5 plugins failed	
Failed:	
PII via Direct Exposure	16.67%
PII via Session Data	16.67%

Privacy Violation	8.33%
PII via Social Engineering	8.33%
Passed:	
PII via API/Database	0.00%
Not Tested:	
Cross-Session Data Leakage	Not Tested

09. Misinformation		2 / 2 plugins failed
Failed:		
Hallucination		33.33%
Overreliance		16.67%
Not Tested:		

OWASP Top 10 for Agentic Applications ⓘ High

Framework Results		5 / 16 failed
Failed:		
✖	Excessive Agency	66.67%
✖	Hallucination	33.33%
✖	Overreliance	16.67%
✖	Resource Hijacking	8.33%
✖	Entity Impersonation	8.33%
Passed:		
✔	ASCII Smuggling	0.00%
✔	Violent Crime Content	0.00%
✔	PII via API/Database	0.00%
ⓘ	System Prompt Override	Not Tested
ⓘ	Indirect Prompt Injection	Not Tested
ⓘ	Intent	Not Tested
ⓘ	Model Context Protocol	Not Tested
ⓘ	RBAC Implementation	Not Tested
ⓘ	Function-Level Authorization Bypass	Not Tested
ⓘ	Object-Level Authorization Bypass	Not Tested
ⓘ	Indirect Prompt Injection	Not Tested
ⓘ	Model Context Protocol	Not Tested
ⓘ	Command Injection	Not Tested
ⓘ	SQL Injection	Not Tested
ⓘ	SSRF Vulnerability	Not Tested
ⓘ	Agentic Memory Poisoning	Not Tested
ⓘ	Indirect Prompt Injection	Not Tested

EU AI Act ⓘ

[illegible]

Indirect Prompt Injection	Not Tested
RBAC Implementation	Not Tested
Cross-Session Data Leakage	Not Tested
Disinformation Campaigns	Not Tested
Divergent Repetition	Not Tested
Disinformation Campaigns	Not Tested
Tool Discovery	Not Tested

Disability Bias	Not Tested
Age Bias	Not Tested
Gender Bias	Not Tested
Race Bias	Not Tested
Disability Bias	Not Tested
Race Bias	Not Tested
Gender Bias	Not Tested

ISO/IEC 42001 ⓘ

Critical

Framework Results

11 / 16 failed

Failed:

⊗

Excessive Agency

66.67%

⊗

Hallucination

33.33%

⊗

Overreliance

16.67%

⊗

PII via Direct Exposure

16.67%

⊗

PII via Session Data

16.67%

⊗

Resource Hijacking

8.33%

⊗

Hate Speech

8.33%

⊗

Privacy Violation

8.33%

⊗

PII via Social Engineering

8.33%

⊗

System Prompt Disclosure

8.33%

⊗

Entity Impersonation

8.33%

Passed:

✔

ASCII Smuggling

0.00%

✔

Violent Crime Content

0.00%

✔

PII via API/Database

0.00%

ⓘ

Child Exploitation

Not Tested

ⓘ

Command Injection

Not Tested

ⓘ

SQL Injection

Not Tested

ⓘ

SSRF Vulnerability

Not Tested

ⓘ

Debug Interface Exposure

Not Tested

ⓘ

WMD Content

Not Tested

ⓘ

Disinformation Campaigns

Not Tested

ⓘ

Unverifiable Claims

Not Tested

ⓘ

Age Bias

Not Tested

ⓘ

Disability Bias

Not Tested

ⓘ

Gender Bias

Not Tested

GDPR ⓘ

Critical

Framework Results

8 / 16 failed

Failed:

✖

Hallucination

33.33%

✖

PII via Direct Exposure

16.67%

✖

PII via Session Data

16.67%

✖

Overreliance

16.67%

✖

Privacy Violation

8.33%

✖

PII via Social Engineering

8.33%

✖

Hate Speech

8.33%

✖

System Prompt Disclosure

8.33%

Passed:

✔

ASCII Smuggling

0.00%

✔

Violent Crime Content

0.00%

✔

PII via API/Database

0.00%

ⓘ

RBAC Implementation

Not Tested

ⓘ

Object-Level Authorization Bypass

Not Tested

ⓘ

Function-Level Authorization Bypass

Not Tested

ⓘ

Command Injection

Not Tested

ⓘ

SQL Injection

Not Tested

ⓘ

SSRF Vulnerability

Not Tested

ⓘ

Debug Interface Exposure

Not Tested

ⓘ

RBAC Implementation

Not Tested

ⓘ

Function-Level Authorization Bypass

Not Tested

ⓘ

Object-Level Authorization Bypass

Not Tested

ⓘ

Disinformation Campaigns

Not Tested

ⓘ

Cross-Session Data Leakage

Not Tested

ⓘ

Age Bias

Not Tested

ⓘ

Disability Bias

Not Tested

DoD AI Ethical Principles ⓘ		Critical
01. Responsible		3 / 3 plugins failed
Failed:		
⊗	Excessive Agency	66.67%
⊗	Overreliance	16.67%
⊗	Resource Hijacking	8.33%
Not Tested:		
ⓘ	Goal Misalignment (Goodhart's Law)	Not Tested
02. Equitable		1 / 1 plugins failed
Failed:		
⊗	Hate Speech	8.33%
Not Tested:		
ⓘ	Age Bias	Not Tested
ⓘ	Disability Bias	Not Tested
ⓘ	Gender Bias	Not Tested
ⓘ	Race Bias	Not Tested
03. Traceable		1 / 1 plugins failed
Failed:		
⊗	Hallucination	33.33%
Not Tested:		
ⓘ	RAG Source Attribution	Not Tested
ⓘ	Disinformation Campaigns	Not Tested
ⓘ	Unverifiable Claims	Not Tested
04. Reliable		7 Untested
Not Tested:		
ⓘ	Command Injection	Not Tested
ⓘ	SQL Injection	Not Tested
ⓘ	SSRF Vulnerability	Not Tested
ⓘ	Debug Interface Exposure	Not Tested
ⓘ	Disinformation Campaigns	Not Tested
ⓘ	Dangerous Activity Content	Not Tested
ⓘ	Reasoning DoS	Not Tested
05. Governable		2 / 2 plugins failed
Failed:		
⊗	Excessive Agency	66.67%
⊗	Resource Hijacking	8.33%

Resource Hijacking		
Not Tested:		
Indirect Prompt Injection		Not Tested
System Prompt Override		Not Tested
RBAC Implementation		Not Tested
Function-Level Authorization Bypass		Not Tested
Object-Level Authorization Bypass		Not Tested
Tool Discovery		Not Tested